a/v запис: https://drive.google.com/file/d/1zLttLm7myn7Q8rozmJ2RjBIvlvccetFV/view?usp=sharing

НЕ СЛІПИЙ ПІДПИС

Принципи Електронного Цифрового Підпису (ЕЦП) тісно повязані із принципами підпису звичайного.

Проведемо порівняльний огляд таких сутностей, як «цифрові підписи» і «підписи звичайні».

Поговоримо про цифрові підписи і звичайні.

Власноручні підписи з давніх давен використовуються для доведення авторства та достовірності (справжності) документа, або згоди із змістом його.

У чому полягає користь звичайного підпису?

Якими є ідеальні риси звичайного підпису?.

1. Достовірність підпису – власний підпис переконує отримувача документа в тому, що підписант поставив підпис свідомо.

2. Непідробність власного підпису – вона доводить, що саме той, хто підписав (і ніхто інший) поставив підпис свідомо.

3. Власний підпис не може бути використаний окремо від документа, або повторно, бо він є частиною документа.

Шахрай не може перенести підпис на інший документ (спроба підробити підпис вважається шахрайством, злочином).

4. Підписаний власним підписом документ не можна змінити після того, як він був підписаний.

Підписаний документ має зберігати свій початковий (оригінальний, original) вигляд і стан.

Підписаний документ з виявленими слідами змін у тексті чи його вигляді, написанні літер, за наявності помарок, підчисток тощо, вважається зіпсованим і втрачає свою валідність.

Саме тому власники таких документів (різного призначення) ретельно зберігають їх від «небажаних впливів», і турбуються про збереження їх первісного вигляду і стану.

5. Від власного підпису неможливо відректися. Підпис і документ є єдиним матеріальним об'єктом.

Підписант не зможе у майбутньому стверджувати, що він не підписував власним підписом документ, або не згоден з його змістом.

Але! …

Насправді, жодне із цих тверджень не є цілком справедливим, чи повністю виконуваним.

Вони можуть розглядатися лише як ідеальні властивості, вимоги до процедури, результату і використання підписаного документа.

Підпис, нажаль, можна підробити, перевести з одного аркуша на інший.

А сам документ може бути змінений після підписання (нажаль, маємо такі кейси у Верховній раді за останні 20 р.).

Суспільствам доводиться терпіти ці негаразди, не маючи інших засобів, що забезпечують омріяні вище властивості підпису, і це вже не одне тисячоліття.

Шахрайство, недоброчесність є важкою проблемою кожного суспільства. Воно важко виявляється, важко доводиться і ще важче його позбутися.

Впровадження підпису з такими бажаними властивостями на обчислювальних пристроях має певні проблеми:

- можна легко виокремити правильний ручний підпис (його графічне зображення) із одного документа (скан, фото) і переставити його в інший;

- присутність такого власного підпису на документі, у певних випадках, нічого достовірного не означає,

- комп'ютерні файли (їх тексти) легко змінити після того, як вони були підписані власним звичайним підписом.

Звернімо увагу на цифровий

НЕ СЛІПИЙ ПІДПИС

Принципи Електронного Цифрового Підпису (ЕЦП)

ЕЦП з Посередником

Підпис документа (не сліпий!) за допомогою симетричного криптоалгоритма і посередника.

Актори: користувачі А та В, посередник П.

Сценарій: Користувач А збирається підписати цифрове повідомлення М і надіслати його до В.

Протокол:

0. П надає А секретний ключ Ка, а В – секретний ключ Кв (key management).

1. А зашифровує М на ключі Ка і надсилає до П.

2. П розшифровує М на ключі Ка.

3. П додає до М твердження, що він дійсно отримав повідомлення від А і зашифровує ПМ на ключі Кв.

4. П надсилає зашифроване ПМ до В.

5. В розшифровує криптограму від П на ключі Кв. Він може прочитати і повідомлення М від А, і твердження П (якому всі довіряють), що воно дійсно від А, є достовірним і автентичним.

Звідки П знає, що М надіслано саме від А ?

Цей висновок він виносить із факту успішного шифрування / дешифрування на ключі Ка, спираючись на конфіденційність комунікації.

Чи відповідає це вимогам підпису на папері?

1. **Підпис можна вважати достовірним.**

П – посередник, він користується довірою спільноти (втрата довіри клієнтів – кінець професійної діяльності для нього).

Підтвердження від П слугує доказом достовірності і автентичності М для В.

2. Підпис можна вважати непідробним.

Тільки А та П знають Ка. Але П довіряють.

Тому висновок – тільки А міг надіслати повідомлення М до П, на ключі Ка.

Якщо хтось інший спробує видати себе за А, то П виявить це на кроці 2 Протоколу підпису, бо ніхто крім А та П не знає ключ Ка.

3. Цей підпис неможна використати повторно.

Якщо В спробує приєднати підтвердження П до іншого повідомлення, то А, наприклад, виявить це і заявить протест.

П (чи хтось іще, з більшою довірою спільноти, контролер, аудитор) попросить у В надати його «повідомлення» і візьме криптограму від А.

Контролер зашифрує «повідомлення» від В на ключі Ка і порівняє із криптограмою від А – результат не співпаде! То , виявлено шахрайство.

Вочевидь, В не знає Ка, то і не зможе підробити, чи зімітувати фальшиве «повідомлення» нібито від користувача А, щоби надіслати його до П.

4. Підписаний документ не можна змінити.

Якщо В спробує змінити текст вже отриманого повідомлення від А, то П зможе виявити це шляхом аудиту із п.3 вище.

5. Від власного підпису неможливо відректися.

Якщо А пізніше ствердить, що він не підписував такого повідомлення до В через П, то підтвердження від П, що є на руках у В, доведе зворотнє.

Таким чином, виходимо з того, що всі довіряють П, і все, що він сказав – є істина!

(і дай Боже, щоби він не був шахраєм).

(41)

Якщо В захоче продемонструвати комусь, наприклад К, повідомлення М від А і довести його достовірність, то щоби не розкривати власний секретний ключ Кв, він може звернутися до П:

1. В зашифровує ПМ на ключі Кв і надсилає його до П.

2. П розшифровує отриману криптограму на ключі Кв.

3. П перевіряє у своїй БД, пересвідчується у наявності такого факту і підтверджує, що відправником оригінального текста М був саме А (що скористався відомим лише їм обом ключем Ка).

4. П шифрує отриманий ним від В пакет ПМ на ключі Кк, який він (П) надавав саме К і надсилає криптограму до К.

5. К розшифровує цю криптограму на ключі Кк, так він може прочитати оригінал повідомлення М і оригінальне підтвердження від П, що М було відправлено саме від А.

Ці Протоколи є працездатними, але вимагають від П чималих витрат часу та ресурсів:

- він має постійно бути посередником між кожною парою людей, суб'єктів, що бажають обмінюватися підписаними повідомленнями;

- він має вести і зберігати БД з повідомленнями і підтвердженнями;

- він виступає «вузькою ланкою» системи.

Посередника П з такими характеристиками, якому будуть довіряти всі користувачі, важко створити і зберегти.

Він має бути абсолютно надійним: наприклад, якщо він зробить 1 помилку на 10 000 підписів, він втратить довіру користувачів, відновити яку буде вкрай важко.

Він має бути абсолютно безпечним: якщо його БД із секретними ключами Кі буде скомпрометована, то всі підписи і підтвердження стануть марними.

Бо у результаті такого інциденту можна очікувати появу фальшивих документів М, підтверджених чи підписаних П, без можливості перевірити факт їх створення і засвідчення ним. А це є шлях до хаосу.

Ця схема працездатна, але вона не зручна у практичному застосуванні.

* * * * *

ПІДПИС ПОВІДОМЛЕННЯ M НА БАЗІ КРИПТОГРАФІЇ З ВІДКРИТИМИ КЛЮЧАМИ.

Відомі алгоритми з відкритими ключами, що можна застосовувати для ЕЦП.

Наприклад, RSA для постановки ЕЦП вимагає від відправника A зашифрувати документ M на власному приватному ключі da.

Перевірити підпис може будь-хто, у кого є відкритий ключ ea, математично зв'язаний із da.

Протокол ЕЦП RSA тут наступний:

1. А зашифровує М власним приватним ключем (da, na). Варто нагадати, що у RSA ключ це є пара чисел.

2. А надсилає криптограму безпосередньо до В.

3. В розшифровує документ М публічним ключем (ea, na), наприклад, із сертифіката відкритого ключа.

Тут не розглядаємо колізії виходу криптограми за межі алфавіту ні при різних na та nb у різних користувачів. Цієї колізії легко уникнути правильною побудовою Протоколу RSA.

Цей Протокол ефективніше попереднього, з Посередником. Тут немає потреби в участі П ні для підпису документа М, ні для верифікації його, ні для розв'язку суперечок.

Якщо, наприклад, B не досяг успіху на кроці 3, то підпис документа M не верифіковано і B просто відкидає криптограму із M, або M як недостовірні.

Такий підпис ЕЦП RSA відповідає всім вимогам (сформульованим вище):

1. Підпис є достовірним.

Якщо B розшифровує криптограму відкритим ключем A, він знає, що підписати документ M міг тільки A власним приватним ключем (da, na).

2. Підпис є непідробний.

Бо тільки *A* знає свій приватний ключ (da, na) і ніхто інший не міг поставити підпис на M (за умов виключення компрометації ключа da).

3. Цей підпис не можна використати повторно.

Він є функцією аргументу «документ, текст M» і не може бути просто перенесений на інший документ.

4. Підписаний документ не можна змінити.

Після будь-якої зміни документа M, підпис не буде верифікуватися на публічному ключі підписанта *A*.

5. Підписант *A* від підпису на M не зможе відректися.

Бо верифікатор, субєкт В може самостійно перевірити дійсність підпису на документі М з допомогою публічного ключа А, а саме (ea, na).

Нагадування про Режими RSA.

- **конфіденційність;**
- **перевірка цілісності і автентичності М (дійсності);**
- **конфіденційність + цілісність та автентичність М.**

Підпис документа М з відміткою часу (timestamp).

19.11.2024

Як В може зшахраювати у Протоколі підпису з відкритими ключами?

Він зможе повторно використати документ M разом з підписом.

Наприклад.

Якщо A поставив ЕЦП під чеком, наприклад на $150 та надіслав його до B.

Отримувач B подасть чек до банку, який перевірить дійсність підпису від A та переведе кошти з рахунку A на рахунок B.

Шахрай B зберіг копію електронного чека та через кілька днів знову подає чек до банку, який перевірить дійсність підпису від A та переведе кошти з рахунку A на рахунок B.

Так може повторюватися довго і ч/з різні банки. Якщо А не слідкує регулярно за рухом коштів на своєму рахунку, то він постраждає від шахрайства.

Ось чому у подібних сценаріях у ЕЦП додають відмітку часу (timestamp), а також спеціальні дані, відомі лише легальним користувачам системи,як solt.

Дата та час факта підписання документа додаються до текста і підписуються разом з усім вмістом повідомлення.

Банк зберігає цей timestamp у своїй БД.

Тому, якщо В намагатиметься отримати кошти вдруге, то банк, який перевіряє timestamp ч/з свою БД, виявить факт оплати чека з тією ж timestamp і тоді назве В шахраєм (з усіма наслідками у межах законодавства).

Підпис документа M в асиметричних алгоритмах з відкритими ключами та хеш-функціями (варіант).

Економія часу на великих документах (за обсягом) з допомогою хеш-функцій веде до зростання ефективності системи підписання і верифікації ЕЦП.

1. A добуває дайджест h = hash (M) обчисленням.

2. A зашифровує h дайджест на власному приватному ключі da і отримує sign(h).

3. A надсилає (M ; sign(h)) до B.

4. В обчислює h* = hash (M) на приймальному боці.

В розшифровує h = Decipher {sign(h); ea} на відкритому ключі ea відправника A.

Якщо h* = h, то підпис верифіковано.